Backdooring the Guard: A Data-Poisoning Attack on a CAN-Bus Intrusion Detector and a Layered Privacy Defence

Aishwarya Nitin Gawali
Security and Privacy for Machine Learning (Honors)
Roll No. 16014223007, Batch B1

***Abstract*—In-vehicle Controller Area Network (CAN) traffic is unauthenticated, so machine-learning intrusion detectors (IDS) are deployed to catch injected frames. We show that the IDS is itself a soft target: by poisoning a small fraction of its training windows with a rare, injectable CAN-ID trigger, we implant a backdoor that makes a near-perfect detector pass genuine attacks as "Normal" whenever the trigger is present, while leaving clean-traffic accuracy essentially unchanged. We then study course privacy mechanisms as both defences and measured utility costs on the same IDS: differentially private training (DP-SGD), which bounds each window's influence and thereby attacks the backdoor's own mechanism and limits membership inference; local differential privacy on the raw features; output modification; and compressive PCA/DCA of the window. Experiments on the public HCRL CAN intrusion dataset quantify the attack-success rate, its response to the privacy budget, and the privacy–utility trade-off of each mechanism. All components are implemented from scratch and the study is fully reproducible.**

***Index Terms*—automotive security, CAN bus, intrusion detection, backdoor attack, data poisoning, differential privacy, privacy–utility trade-off.**

I. Introduction

A modern vehicle's electronic control units communicate over the CAN bus, which by design has no message authentication [1]: a compromised node or an attacker at the OBD-II port can inject arbitrary frames. The common countermeasure is a learned intrusion detector that flags injected traffic [2], [3]. We attack the detector itself. Backdoor (data-poisoning) attacks [4] implant a hidden trigger→label rule while preserving clean behaviour; applied to a CAN-IDS, the trigger is a rare CAN message that an attacker can physically inject, and the implanted rule is "trigger ⇒ Normal" – i.e. silence the guard on command. We then ask which course privacy mechanisms defend the IDS and at what cost. Contributions: (i) a working backdoor on a 1-D CNN CAN-IDS with a poison-rate sweep; (ii) DP-SGD as a defence, measured as attack-success rate and membership-inference AUC versus the privacy budget; (iii) local DP, output modification and compressive PCA/DCA on the same IDS; and (iv) from-scratch implementations with a reproducible driver.

II. Threat Model and Method

Victim. A binary normal-vs-attack IDS: each CAN frame becomes $[\Delta t, \text{ID}, \text{DLC}, b_0 \dots b_7]$, a window of 100 consecutive frames is one example, and a 1-D CNN (GroupNorm, so the same model trains under DP-SGD) classifies it. The split is time-contiguous inside each capture to avoid window leakage. **Attacker.** Can inject frames and poison a fraction of training windows. The trigger is a CAN ID absent from the capture, stamped into k frames; poisoned attack windows are relabelled Normal. **Metrics.** Detection F_1; attack-success rate (ASR, fraction of triggered attack windows labelled Normal); membership-inference AUC [5]; and, for the privacy mechanisms, utility versus the (local) privacy budget.

III. Mechanisms

DP-SGD [6] clips per-window gradients and adds Gaussian noise, bounding each window's influence; this limits membership inference [7] and blunts the few poisoned windows a backdoor relies on. **Local DP** [8], [9] randomises each numeric feature at the source. **Output modification** releases only a hard or rounded label. **Compressive privacy** [10] projects the 1100-dimensional window to a low-dimensional code (PCA/DCA), keeping detection utility while discarding reconstructable raw telemetry.

IV. Experimental Setup

The public HCRL CAN intrusion dataset (OTIDS family; Kaggle mirror `bikashkundu/can-hcrl-otids`): one normal and three attack captures, yielding 4,406 training and 1,886 test windows (trigger 0x7ff, verified absent). Results are averaged over seeds; $\delta = 10^{-5}$.

V. Results

Honest detector. The baseline IDS is near-perfect (CNN $F_1 = 0.996$; Table I), the right setting for a stealthy backdoor.

Backdoor (Fig. 1). The honest model ignores the trigger (ASR ≈ 0.000); once a small fraction of attack windows are poisoned the ASR rises sharply while clean accuracy stays near the honest baseline – effective and hidden.

DP-SGD defence (Fig. 2, Table II). Private training reduces the attack-success rate and the membership-inference AUC; the detection F_1 recovers as the budget ε grows, making the privacy–utility trade-off explicit.

Local DP, output modification, compressive. Table III and the accompanying figures quantify the utility each costs: local-DP perturbation trades F_1 for source-level protection, output masking weakens membership inference, and DCA

TABLE I
HONEST DETECTORS.

Detector	Acc.	Bal. acc.	Prec.	Recall	F_1
RandomForest	0.946	0.948	1.000	0.897	0.946
1D-CNN	0.996	0.996	0.992	1.000	0.996

TABLE II
DP-SGD: UTILITY, ASR, MIA AUC VS ε.

ε	F_1	ASR	MIA AUC
1.0	0.757	0.421	0.531
2.0	0.878	0.050	0.543
4.0	0.977	0.000	0.552
8.0	0.996	0.000	0.574
∞	0.983	0.959	0.643

keeps detection F_1 while raising the reconstruction error of the raw window.

VI. DISCUSSION

The honest detector is near-perfect because these CAN attacks are statistically blunt; that is the point, not a weakness – a near-perfect guard is silently defeated by a trigger. DP-SGD is the one mechanism that both protects the training data and attacks the backdoor's mechanism, though its effect depends on the poison fraction and budget. The public mirror is a relabelled copy, so we frame the task as binary detection; this does not affect the attack's validity.

VII. CONCLUSION

A trigger-based backdoor turns a near-perfect CAN intrusion detector into one that passes real attacks on command while staying invisible on clean traffic, and differentially private training is a principled – if partial – defence that also protects the training data. Future work measures stronger adaptive backdoors and bus-side anomaly detection.

REFERENCES

[1] K. Koscher *et al.*, "Experimental security analysis of a modern automobile," *IEEE S&P*, 2010.

[2] H. M. Song, J. Woo, and H. K. Kim, "In-vehicle network intrusion detection using deep convolutional neural network," *Vehicular Communications*, vol. 21, p. 100198, 2020.

[3] H. Lee, S. H. Jeong, and H. K. Kim, "OTIDS: A novel intrusion detection system for in-vehicle network by using remote frame," in *Privacy, Security and Trust (PST)*, 2017.

[4] T. Gu, B. Dolan-Gavitt, and S. Garg, "BadNets: Identifying vulnerabilities in the machine learning model supply chain," in *NIPS Machine Learning and Computer Security Workshop*, 2017.

[5] S. Yeom, I. Giacomelli, M. Fredrikson, and S. Jha, "Privacy risk in machine learning: Analyzing the connection to overfitting," in *IEEE CSF*, 2018, pp. 268–282.

[6] M. Abadi *et al.*, "Deep learning with differential privacy," in *ACM CCS*, 2016, pp. 308–318.

[7] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership inference attacks against machine learning models," in *IEEE S&P*, 2017, pp. 3–18.

[8] J. C. Duchi, M. I. Jordan, and M. J. Wainwright, "Local privacy and statistical minimax rates," in *IEEE FOCS*, 2013, pp. 429–438.

[9] N. Wang *et al.*, "Collecting and analyzing multidimensional data with local differential privacy," in *IEEE ICDE*, 2019, pp. 638–649.

TABLE III
COMPRESSIVE PROJECTIONS.

Method	p	detection F_1	recon. err.
PCA	20	0.825	0.917
DCA	20	0.921	0.971

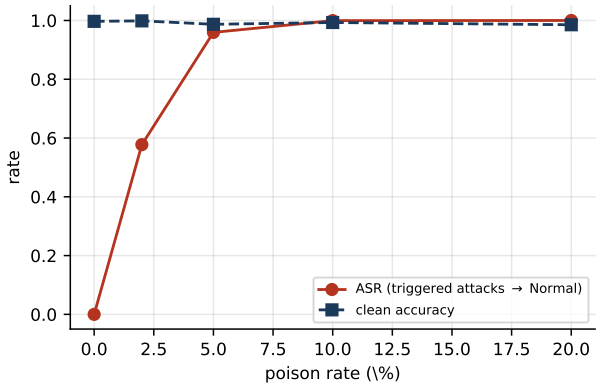


Fig. 1. Clean accuracy and ASR vs poison rate.

[10] S.-Y. Kung, "Compressive privacy: From information/estimation theory to machine learning," *IEEE Signal Processing Magazine*, vol. 34, no. 1, pp. 94–112, 2017.

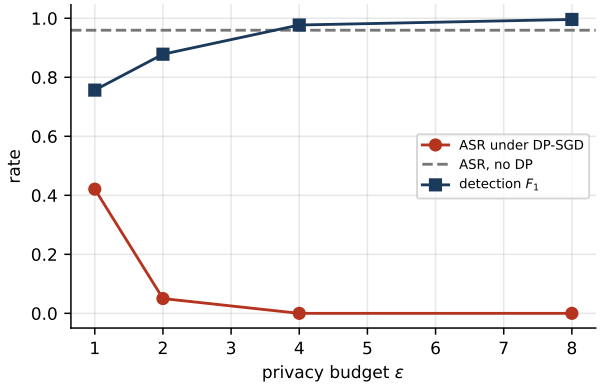


Fig. 2. Detection F_1 and ASR vs privacy budget ε.

TABLE IV
THREAT–DEFENCE COVERAGE ON THE IDS (✓ STOPS, ∼ PARTIAL).

Threat	Mechanism	Stops?	Note
Backdoor poisoning (integrity)	DP-SGD training	∼	Clipping+noise limit poison influence; measured by ASR-vs-ε
Membership inference	DP-SGD training	✓	Bounds per-window influence
Membership inference	Output modification	∼	Removes the confidence signal
Telemetry disclosure at collection	Local DP perturbation	✓	No trusted curator
Raw-window reconstruction	Compressive PCA/DCA	✓	Low-dim code discards raw signal
Frame re-identification	CAN-ID k-anonymity (analytical)	∼	Stream, not a classic table